

Bachelor of Information System

IS2204 - Information System Security

Lecture – 5 : Email and Document Security

Kasun De Zoysa
kasun@ucsc.cmb.ac.lk



UNIVERSITY OF COLOMBO SCHOOL OF COMPUTING

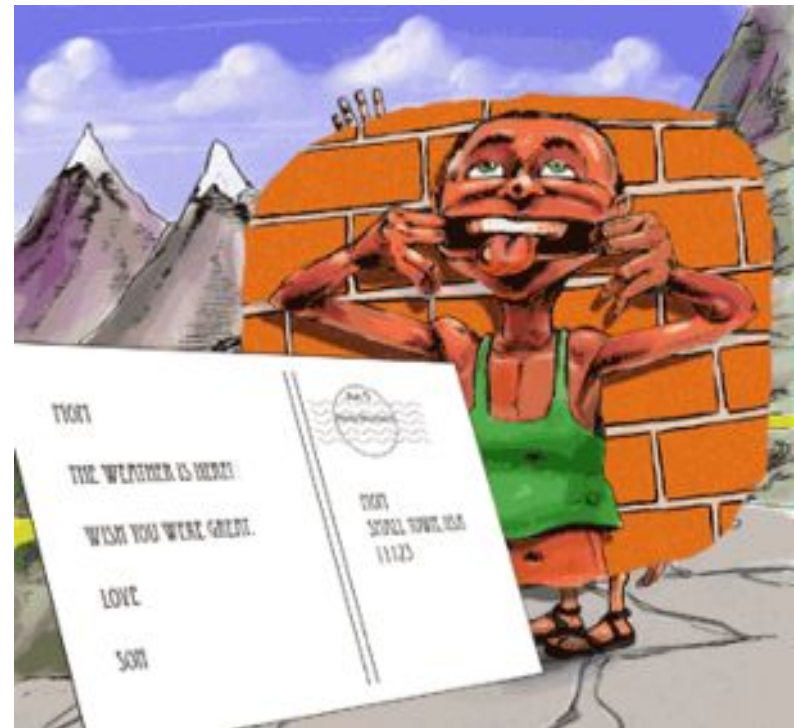
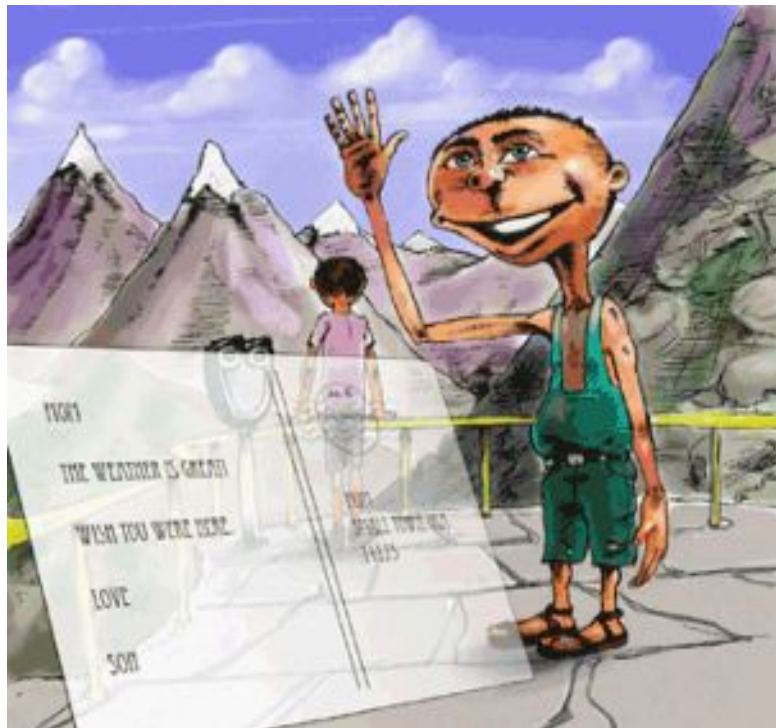


Cybersecurity Protocols

-
- **PGP** : E-Mail, RFC2015
 - **S/MIME** : E-Mail, RFC2311, RFC2634
- } Email Security
-
- **S-HTTP** : Web Browsing, RFC2660
 - **PCT** : TCP/IP-level Encryption
 - **SSL** : TCP/IP-level Encryption, Netscape
 - **TLS** : TCP/IP-level Encryption, RFC2246
- } Web Security
-
- **Cybercash** : Electronic Transactions, RFC1898
 - **SET** : Secure Electronic Funds Transactions
 - **BitCoin**: Blockchain Cryptocurrencies
- } Payment Security
-
- **SSH** : Remote Login
 - **DNSSEC** : Domain Name System, RFC2065
 - **IPSec** : Packet-Level Encryption, RFC2401
 - **Tor**: Onion Routing Protocol
- } Network Security
-

Email is in the Clear

Email – A Postcard Written in Pencil



http://www.cert.org/homeusers/email_postcard.html

E-mail Security

- S/MIME
 - Secure/Multipurpose Internet Mail Extension
 - S/MIME will probably emerge as the industry standard.
 - PGP for personal e-mail security
- Pretty Good Privacy (PGP) (www.pgp.com)
 - Philip R. Zimmerman is the creator of PGP.
 - PGP provides a confidentiality and authentication service that can be used for electronic mail and file storage applications.



MIME content

MIME content headers

text/plain
text/richtext
multipart/mixed
multipart/parallel
multipart/alternative
multipart/digest
message/rfc822
message/partial
message/external-body
image/jpeg
image/gif
video/mpeg
audio/basic
application/postscript
application/octet-stream

MIME content headers

From: Dr William Buchanan
<w.buchanan@napier.ac.uk>
MIME-Version: 1.0
To: w.buchanan@napier.ac.uk
Subject: Any subject
Content-Type: multipart/mixed;
boundary="boundary name"
This part of the message will be
ignored.
-- boundary name
Content-Type: multipart/mixed;
boundary="boundary name"
This is the first mail message part.
-- boundary name
And this is the second mail message
part.
-- boundary name --

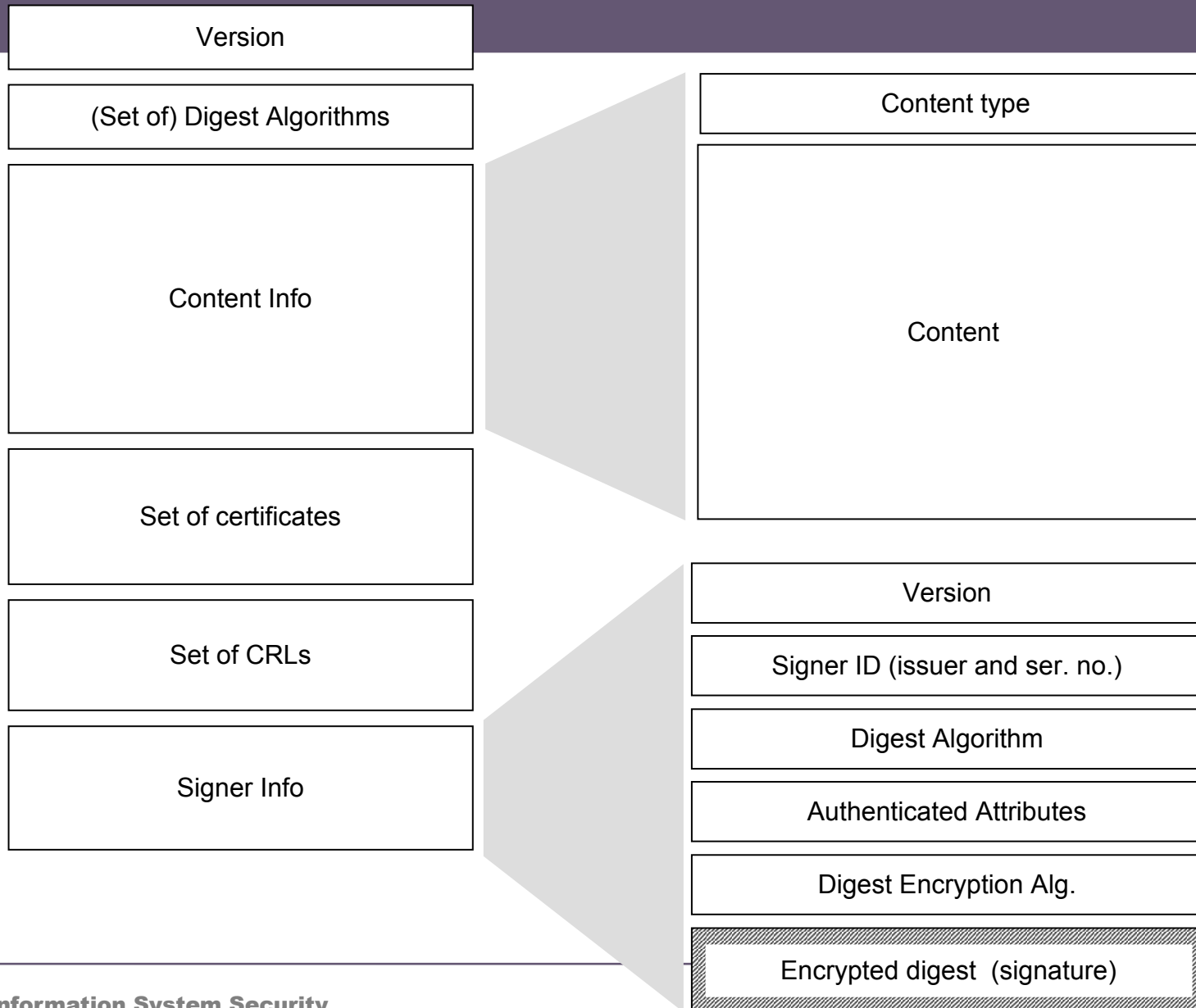
- Multipurpose Internet Mail Extensions (MIME) is an Internet standard that extends the format of email messages to support text in character sets other than ASCII, as well as attachments of audio, video, images, and application programs.
- Message bodies may consist of multiple parts, and header information may be specified in non-ASCII character sets.

Securing a MIME entity

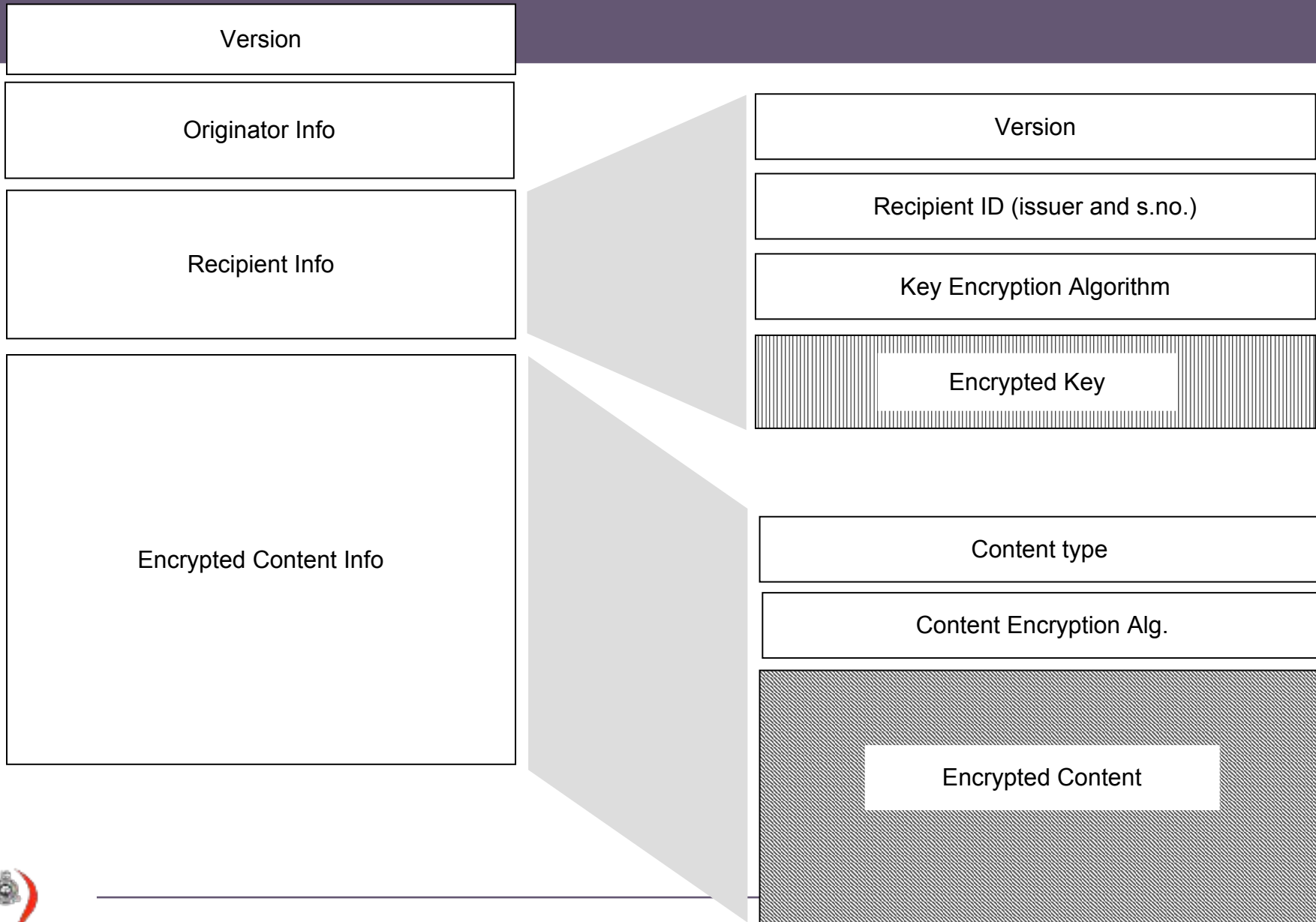
- MIME entity is prepared according to the normal rules for MIME message preparation
- prepared MIME entity is processed by S/MIME to produce a PKCS object
- the PKCS object is treated as message content and wrapped in MIME



PKCS7 “signed data”



PKCS7 “enveloped data”



Enveloped data – Example

Content-Type: application/pkcs7-mime; smime-type=enveloped-data; name=smime.p7m

Content-Transfer-Encoding: base64

Content-Disposition: attachment; filename=smime.p7m

rfvbnj756tbBghyHhHUujhJhjH77n8HHGT9HG4VQpfyF467GhIGfHfYT6
7n8HHGghyHhHUujhJh4VQpfyF467GhIGfHfYGTTrfvbnjT6jH7756tbB9H
f8HHGTTrfvhJhjH776tbB9HG4VQbnj7567GhIGfHfYT6ghyHhHUujpfyF4
0GhIGfHfQbnj756YT64V

Clear-signed data – Example

Content-Type: multipart/signed; protocol="application/pkcs7-signature";
micalg=sha1; boundary=boundary42

--boundary42
Content-Type: text/plain

This is a clear-signed message.

--boundary42
Content-Type: application/pkcs7-signature; name=smime.p7s
Content-Transfer-Encoding: base64
Content-Disposition: attachment; filename=smime.p7s

ghyHhHUujhJhjH77n8HHGTrfvbnj756tbB9HG4VQpfyF467GhIGfHfYT6
4VQpfyF467GhIGfHfYT6jH77n8HHGghyHhHUujhJh756tbB9HGTrfvbnj
n8HHGTrfvhJhjH776tbB9HG4VQbnj7567GhIGfHfYT6ghyHhHUujpfyF4
7GhIGfHfYT64VQbnj756

--boundary42--

S/MIME Functions

- Enveloped Data: Encrypted content and encrypted session keys for recipients.
- Signed Data: Message Digest encrypted with private key of “signer.”
- Clear-Signed Data: Signed but not encrypted.
- Signed and Enveloped Data: Various orderings for encrypting and signing.

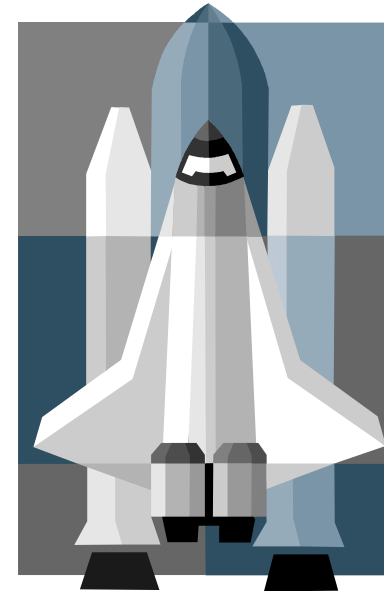
Why Is PGP Popular?

- It is available free on a variety of platforms.
- Based on well known algorithms.
- Wide range of applicability
- Not developed or controlled by governmental or standards organizations



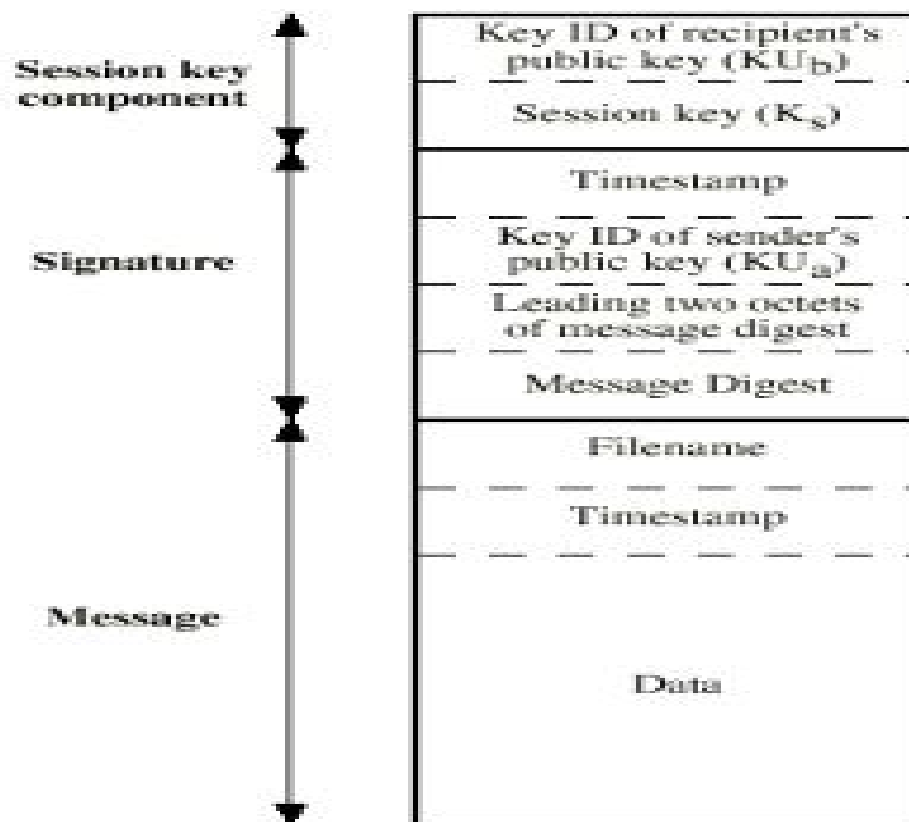
Operational Description

- Consist of five services:
 - Authentication
 - Confidentiality
 - Compression
 - E-mail compatibility

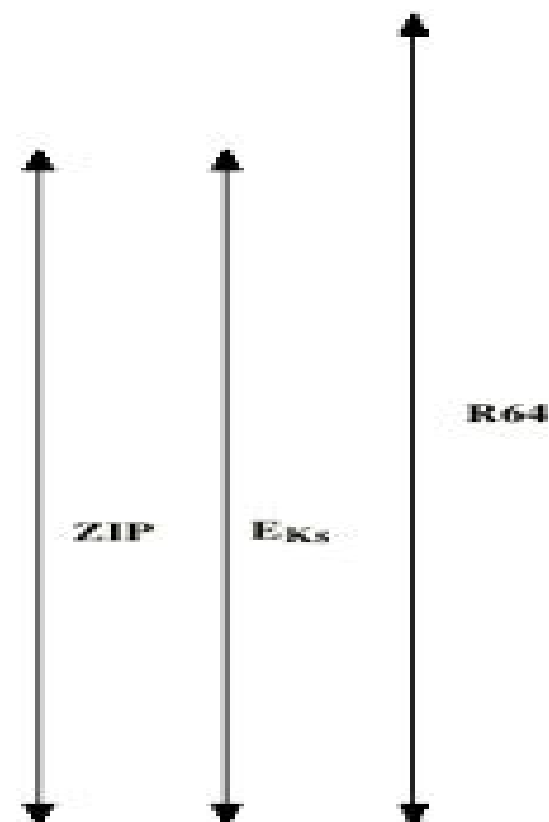


Format of PGP

Content



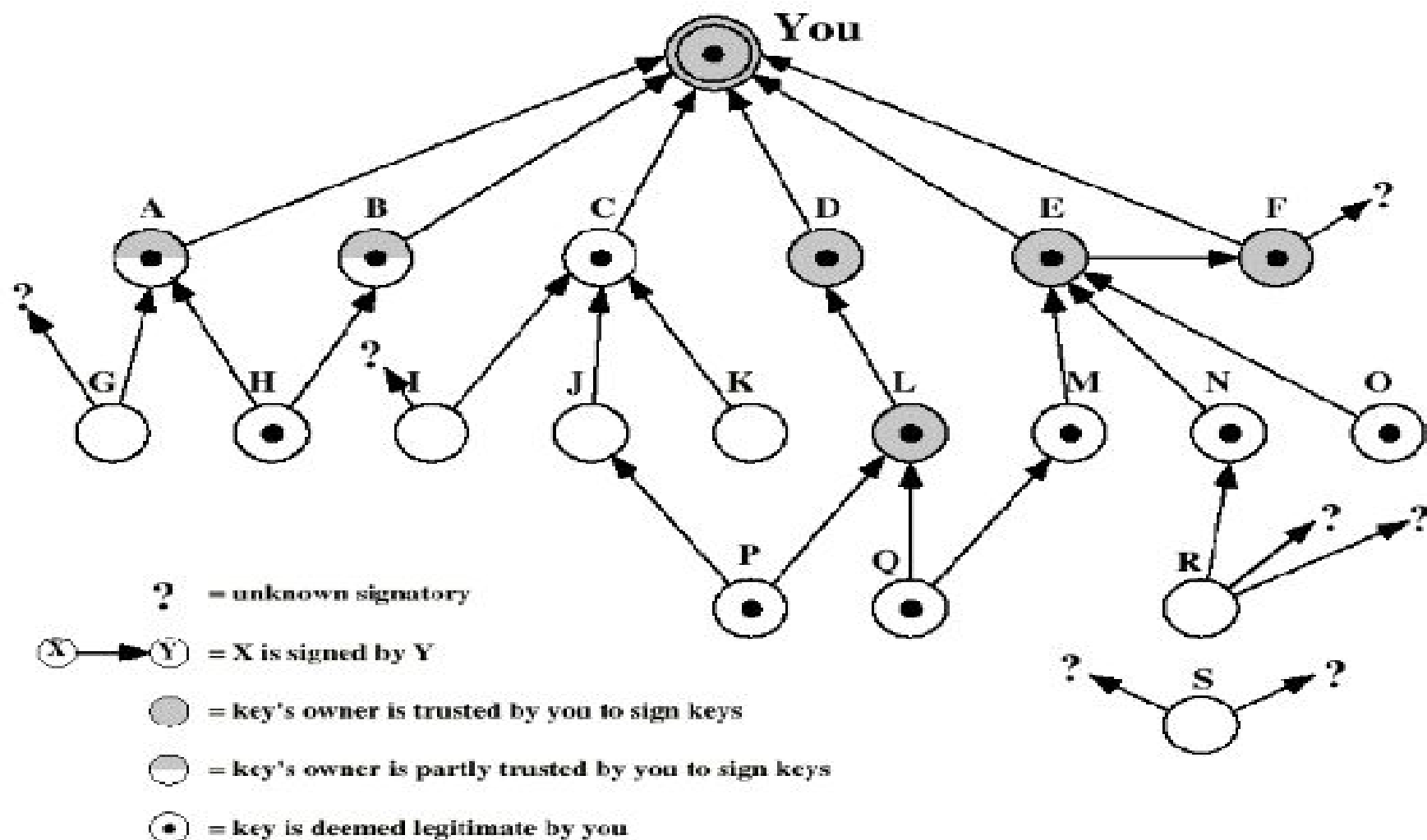
Operation



PGP Key Distribution

- PGP adopts a trust model called the *web of trust*.
- No centralized authority
- Individuals sign one another's public keys, these "certificates" are stored along with keys in key rings.
- PGP computes a *trust level* for each public key in key ring.
- Users interpret trust level for themselves.

PGP Public Keys



Confidential Mode

Gmail's confidential mode does not mean your messages are end-to-end encrypted. Google can still read them. Recipient can always take a screenshot of your message.

Kasun de zoysa has sent you an email via **Gmail confidential mode**:

 Test mail

This message was sent on Mar 21, 2020 at 10:12:46 AM PDT
You can open it by clicking the link below. This link will only work for kasund@yahoo.com.

[View the email](#)

Gmail confidential mode gives you more control over the messages you send. The sender may have chosen to set an expiration time, disable printing or forwarding, or track access to this message. [Learn more](#)

Gmail: Email by Google

Use is subject to the [Google Privacy Policy](#)

Google LLC, 1600 Amphitheatre Parkway, Mountain View, CA 94043, USA

You have received this message because someone sent you an email via Gmail confidential mode.

Google™

 ProtonMail

Secure Email Based
in Switzerland

Secure Your Communications with ProtonMail

[GET YOUR ENCRYPTED EMAIL ACCOUNT](#)

www.mailvelope.com

The image shows a screenshot of the Mailvelope website and its Key Management interface. The top part of the image shows the website's homepage with the URL `mailvelope.com/en` in the browser address bar. The navigation bar includes links for Home, Documentation, FAQ, Blog, Cooperation, and About. The main content area features a green background with the text "Communicating securely with Mailvelope".

Below the homepage, the Key Management interface is shown. It includes a navigation bar with links for Key Management, Encrypt, Decrypt, and Options. The Key Management section has buttons for + Generate, Import, Export, and Refresh. A table lists the keys, with one key highlighted as the default.

Name	Email	Key ID	Created
Kasun De Zoysa Default	kasun.de.zoysa@gmail.com	55F33551762297E7	2019-01-05

On the right side of the Key Management interface, there is a sidebar with the following options:

- Dashboard**: Display all configuration options.
- Keyring**: Manage public and private keys.
- File encryption**: Encrypt one or multiple files.
- Security log**: Review security relevant user actions.

At the bottom of the sidebar, there are two buttons: "Reload Mailvelope" and "Authorize this domain".

What is spam?

- Spam is anonymous, unsolicited junk email sent indiscriminately to huge numbers of recipients.
- What for?
 - Advertising goods and services (often of a dubious nature)
 - Quasi-charity appeals
 - Financial scams
 - Chain letters
 - Phishing attempts
 - Spread malware and viruses



How do spammers harvest email addresses?

– From posts

When you send email to different forums. For example your address will be available to simple, automatic programs that are looking at the header which contain email address (From:, Reply-To:, etc). Spammers may easily build huge lists of potential targets.

– From mailing lists.

Spammer's regularly harvesting email addresses from poorly configured mailing lists.



How do spammers harvest email address?

- **From web pages**

Spammers have programs, which spider through web pages, check mail to: link, and collect the email address.

- **From various web forms**

Some site requests various details via web forms. E.g.; registration forms and guest books. Some of these sites collect the information and sell it to the spammers.



TheHarvester

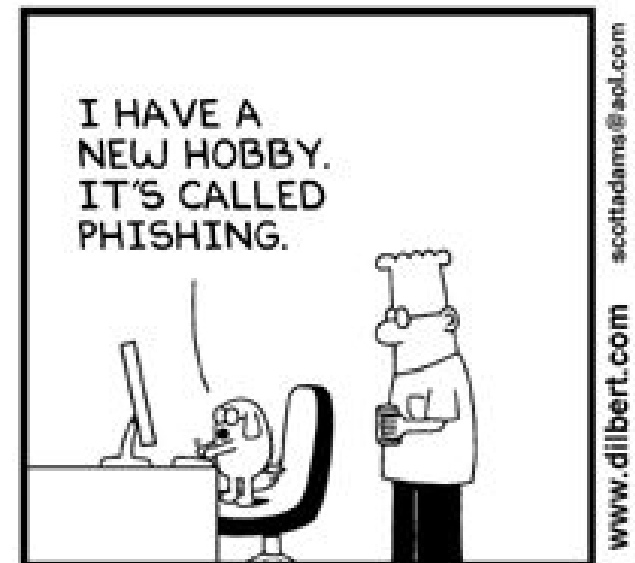
TheHarvester is a tool, written by Christian Martorella, that can be used to gather e-mail accounts and subdomain names from different public sources (search engines, pgp key servers).

- DEMO:

```
theHarvester -d cmb.ac.lk -l 500 -b  
google
```

Phishing

- Phishing is an illegal activity that uses social engineering techniques to trick people into giving out personal information.
- Typically you will receive an email that appears to be from a legitimate business or organization asking for verification of personal or financial information.



© Scott Adams, Inc./Dist. by UFS

Phishing Email

- Information asked for in a phishing email may include:
 - Username, userid, email id, email identity
 - Password
 - ID number
 - Birthdate
- Or there may just be a link to click on that takes you to an official looking web site to enter information.

Phishing Technique

- Link manipulation
 - Technical deception designed to make a link in an email and the spoofed website it leads to, appear to belong to the spoofed organization.
- Spoofed website
 - Looks almost exactly like the real thing
- Website forgery
 - A spoofed website that uses JavaScript to alter the address bar to appear legitimate.
- Filter evasion
 - Misspelled words and images instead of text are used to evade anti-phishing filters.

Phishing Example

Foreign lottery scams are common

MEGAFORTUNE LOTTERY INTERNATIONAL
INTERNATIONAL PROMOTION/PRIZE AWARD DEPT.
REF: MLI/231-ILGI0431/04
BATCH: IPD/17/096/PTNL
RE: WINNING FINAL NOTIFICATION

Sir/Madam, We are pleased to inform you of the result of the Lottery Winners International programs held on the 17th of January 2005. Your e-mail address attached to ticket number 20511465897-6291 with serial number 472-971103 drew lucky numbers 8-66-97-22-71-64 which consequently won in the 3rd category, you have therefore been approved for a sum pay out of US\$ 500,000 000. (five hundred Thousand United States Dollars). CONGRATULATIONS!!!

Due to mix up of some numbers and names, we ask that you keep your winning information very confidential till your claims has been processed and your prize/money Remitted toyou. This is part of our security protocol to avoid double claiming and unwarranted abuse of this program by some participants. All participants were selected through a computer ballot system drawn from over 200,000,000 company and 300,000,000 individual email addresses and names from all over the world. This promotional program takes place annually. We hope with part of your winning you will take part in our next year USD10 million international lottery. To file for your claim, please contact our/your fiducial agent MR.PHILIP GERE of the, MECURY TRUST AGENT TEL: +31-621-488-708 FAX: +31-645-236-856 Email: philipgere900@netscape.net Note that all winning must be claimed not later than 3rd of February 2005. After this date all unclaimed, funds will be included in the next stake.

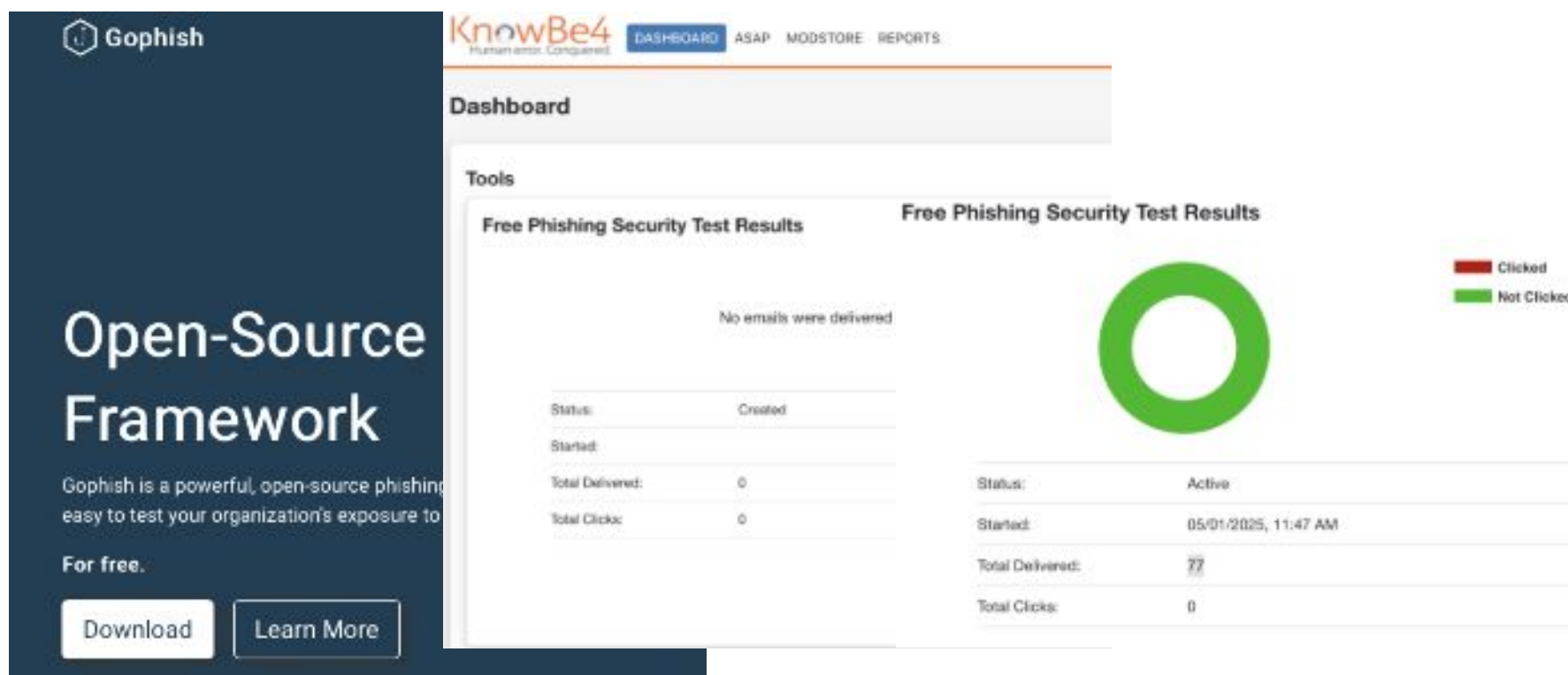
Please note in order to avoid unnecessary delays and complications please remember to quote your reference number and batch numbers in all correspondence. Furthermore, should there be any change of address do inform our agent as soon as possible. Congratulations once more from our members of staff and thank you for being part of our promotional program.

Note: Anybody under the age of 18 is automatically disqualified.

Sincerely yours,
Mrs Ellen Kloos,
Lottery Coordinator
REPLY EMAIL TO philipgere900@netscape.net

Phishing Tests

Gophish: Create your own simulated phishing campaigns and track results with this easy-to-use open source platform:
<https://getgophish.com/>



The screenshot displays the Gophish web interface. On the left is a dark blue sidebar with the Gophish logo and the text "Open-Source Framework". Below this, it states "Gophish is a powerful, open-source phishing framework that is easy to test your organization's exposure to phishing attacks." and "For free." with "Download" and "Learn More" buttons. The main content area has a header with "KnowBe4" and navigation links: "DASHBOARD", "ASAP", "MODSTORE", and "REPORTS". The "Dashboard" section is titled "Tools" and contains two "Free Phishing Security Test Results" panels. The left panel shows "No emails were delivered" and a table with Status: Created, Started: (empty), Total Delivered: 0, and Total Clicks: 0. The right panel shows a large green donut chart representing 77% (77 out of 77) not clicked, with a legend for "Clicked" (red) and "Not Clicked" (green). Below the chart is a table with Status: Active, Started: 05/01/2025, 11:47 AM, Total Delivered: 77, and Total Clicks: 0.

Free Phishing Security Test Results	
Status:	Created
Started:	
Total Delivered:	0
Total Clicks:	0

Free Phishing Security Test Results	
Status:	Active
Started:	05/01/2025, 11:47 AM
Total Delivered:	77
Total Clicks:	0

Links in emails?

- Approach links in an email with caution.
- They might look genuine, but they could be forged.
- Copy and paste the link to your web browser.
- Type in the address yourself.
- Or even Google the company and go to their website from the search results.

Existing anti-spamming techniques



Blacklist/Whitelist:

In blacklist technique, list of domains, mail serves, and email address are defined. Then e-mails come from above address will not be allowed. Whitelist technique is the opposite of blacklist technique.

Integrity Check:

Mail can be check and filter if it has the characteristic of spam. However, identifying the characteristics of a spam is very difficult.

Existing anti-spamming techniques



Reverse DNS Lookup:

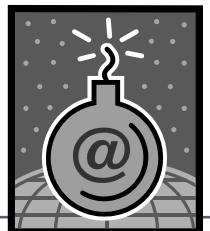
In this technique, when receiving a mail, the IP address of the sending sever is taken and DNS lookup is performed on that address to check whether the e-mail address is a real one or a bogus one.

Rules-based Filtering:

In rule-based filtering, mails are examined according to the specific rules. These rules are defined according to the patterns often used by spammers.

Attachments

- Computer viruses and other malicious software are often spread through email attachments.
- If a file attached to an email contains a virus, it is often launched when you open (or double-click) the attachment.
- Don't open email attachments unless you know whom it is from and you were expecting it.



Email best practices

- Use the BCC field when sending to large distribution lists.
 - Protects recipients email addresses
 - Prevents Reply to All issues
- Avoid use of large distribution lists unless legitimate business purpose.
 - E.g., All Faculty/Staff list
- Beware of Reply to All button
- Don't forward chain email letters.



Document Security

- **Definition:** Protection of documents from unauthorized access, alteration, destruction, or theft.
- **Why it matters:** Sensitive information in the wrong hands can lead to identity theft, fraud, reputational damage, and legal issues.
- **Types of documents:**
 - Personal (e.g., IDs, health records)
 - Corporate (e.g., contracts, HR records)
 - Governmental (e.g., classified reports)
 - Academic & Research data



Document Lifecycle

01

Document Creation

During this critical stage, the information and ideas are collected to transform them into tangible written or digital assets.

02

Document Storage

The second stage is document storage where they should be moved to a secure cloud storage, an internal server, or DMS

03

Document Sharing & Delivery

This stage defines how documents are shared, collaborated on, and edited,.

04

Document Archival or Destruction

This phase is marked by the careful digital preservation and eventual disposal of documents.

Threats to Document

- **Physical threats:**

- Theft, misplacement, fire, water damage
- Unauthorized photocopying or printing

- **Digital threats:**

- Unauthorized access (insider threats or hacking)
- Malware (ransomware, spyware)
- Data leakage via email or removable media
- Cloud sync misconfigurations

Threats to Document

15 Top Threats to consider



Principles of Document Security

- **Confidentiality** – Only authorized users can access.
- **Integrity** – Document content cannot be altered undetected.
- **Availability** – Documents are accessible when needed.
- **Non-repudiation** – Proof of origin and receipt (important for legal documents).

Access Control Mechanisms

- User Authentication
 - Passwords, MFA, SSO (Single Sign-On)
- Role-Based Access Control (RBAC)
 - Principle of Least Privilege (PoLP)
 - Granular document permissions (e.g., read-only, edit)
- Audit Logs
 - Track who accessed/edited what and when

Encryption Techniques

- **At Rest**

- File system encryption (e.g., BitLocker, VeraCrypt)
- Database encryption for document storage systems

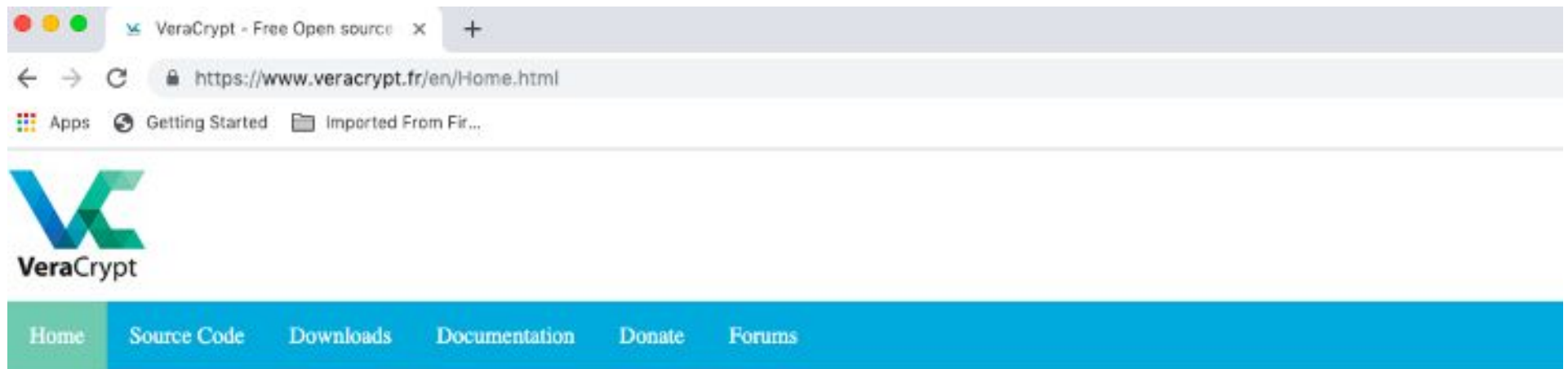
- **In Transit**

- SSL/TLS for web-based file sharing
- Email encryption (S/MIME, PGP)

- **File-Level Encryption (At Rest, InTransit)**

- MS Office: Password-protected files with AES encryption
- PDF encryption (owner vs. user password)

VeraCrypt



VeraCrypt is a free open source disk encryption software for Windows, Mac OSX and Linux. Brought to you by **IDRIX** (<https://www.idrix.fr>) and based on TrueCrypt 7.1a.

VeraCrypt main features:

- Creates a **virtual encrypted disk** within a file and mounts it as a real disk.
- Encrypts an **entire partition or storage device** such as USB flash drive or hard drive.
- Encrypts a **partition or drive where Windows is installed** ([pre-boot authentication](#)).
- Encryption is [automatic, real-time\(on-the-fly\) and transparent](#).
- [Parallelization](#) and [pipelining](#) allow data to be read and written as fast as if the drive was not encrypted.
- Encryption can be [hardware-accelerated](#) on modern processors.
- Provides [plausible deniability](#), in case an adversary forces you to reveal the password: [Hidden volume](#) (steganography) and [hidden operating system](#).
- More information about the features of VeraCrypt may be found in the [documentation](#)

[Donate to help the project](#)                                                                           

Unable to Process Data in Encrypted Form

- Encrypting data at rest is easy but problem is the processing.
- No matter which operating system or technology you choose, if you lose the keys, you will lose your data forever and if your keys become compromised, the data may be at risk.
- Therefore, **key management** is important.



Homomorphic Encryption

(Gentry, 2009)

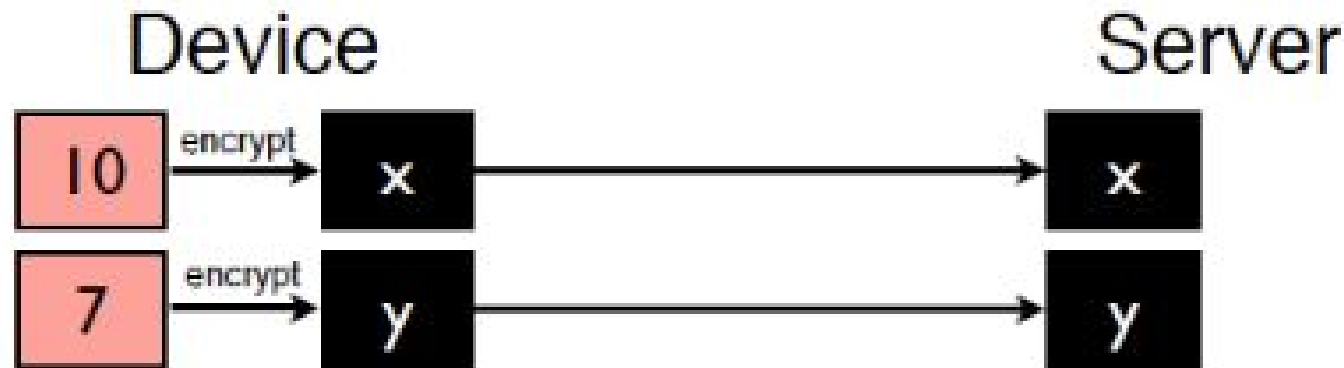
- Take a sensor value S , encrypt it to be S_e
- It is possible to perform arbitrary computations on S_e



Homomorphic Encryption

... ..
(Gentry, 2009)

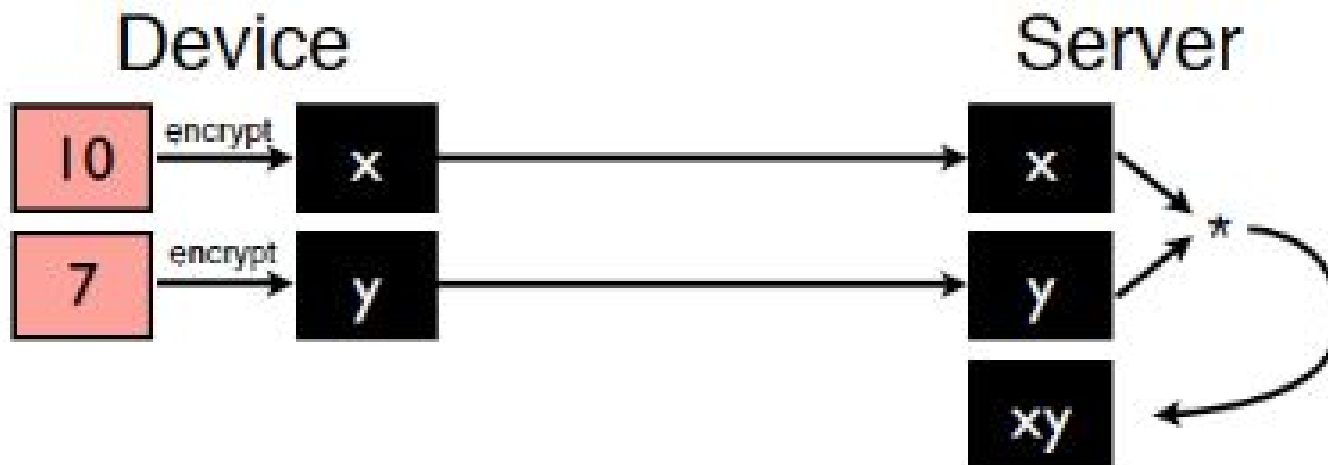
- Take a sensor value S , encrypt it to be S_e
- It is possible to perform arbitrary computations on S_e



Homomorphic Encryption

(Gentry, 2009)

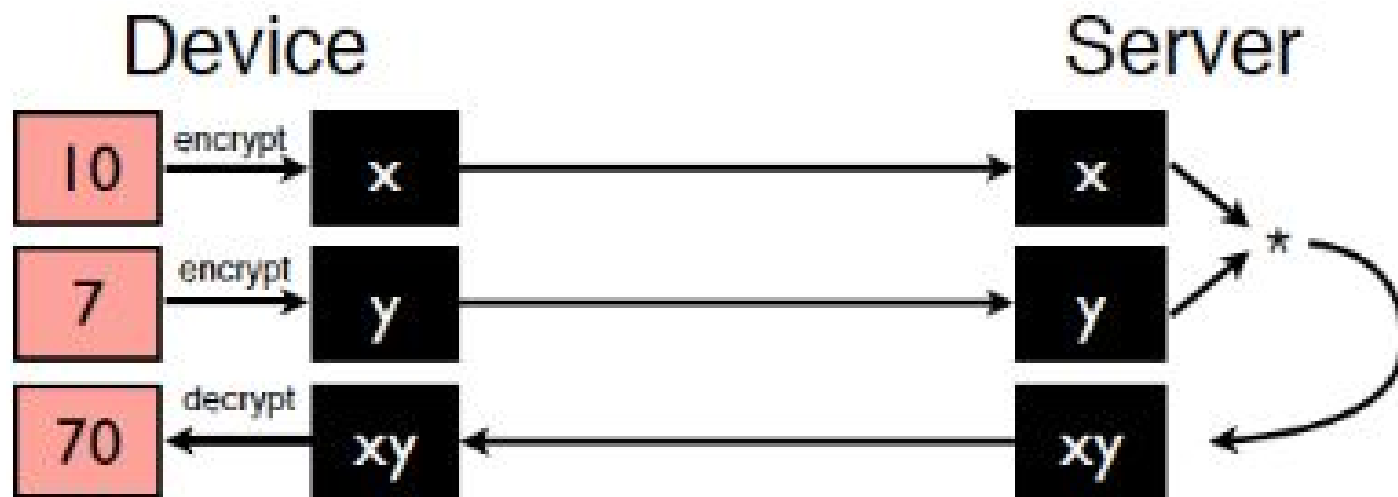
- Take a sensor value S , encrypt it to be S_e
- It is possible to perform arbitrary computations on S_e



Homomorphic Encryption

(Gentry, 2009)

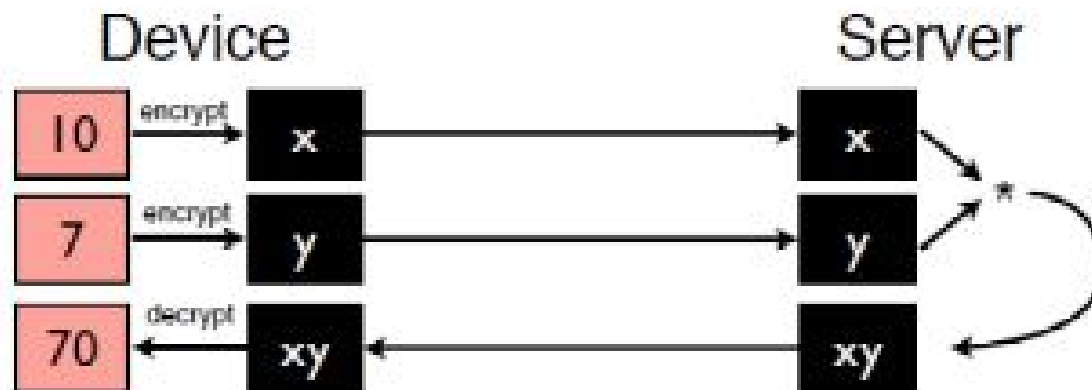
- Take a sensor value S , encrypt it to be S_e
- It is possible to perform arbitrary computations on S_e



Homomorphic Encryption

(Gentry, 2009)

- Take a sensor value S , encrypt it to be S_e
- It is possible to perform arbitrary computations on S_e



- So confidential analytics possible, but not yet practical
 - Computations on S_e are 1,000,000 slower than computations on S
- But can be fast for *specific* computations (e.g., $*$)

Document Authentication and Integrity

- **Hashing**

- Verify document has not been altered (e.g., SHA-256 checksums)

- **Digital Signatures**

- Authenticates the origin and ensures non-repudiation
- Uses public-private key cryptography (PKI)



Digital vs Electronic Signatures

Electronic Signature: A broad term for any digitalized signature, including scanned handwritten signatures, typed names, or click-to-sign options. While convenient, it lacks built-in security measures.

Digital Signature: A more secure type of electronic signature that uses encryption and a certificate-based digital ID to verify the signer's identity and protect document integrity.



Data Loss Prevention (DLP) and Document Monitoring

- DLP tools
 - Identify and block sensitive content leaving the organization
 - Keyword matching, pattern recognition (e.g., credit card numbers)
- Logging & Alerting
 - Behavioral analytics (unusual document access/download)

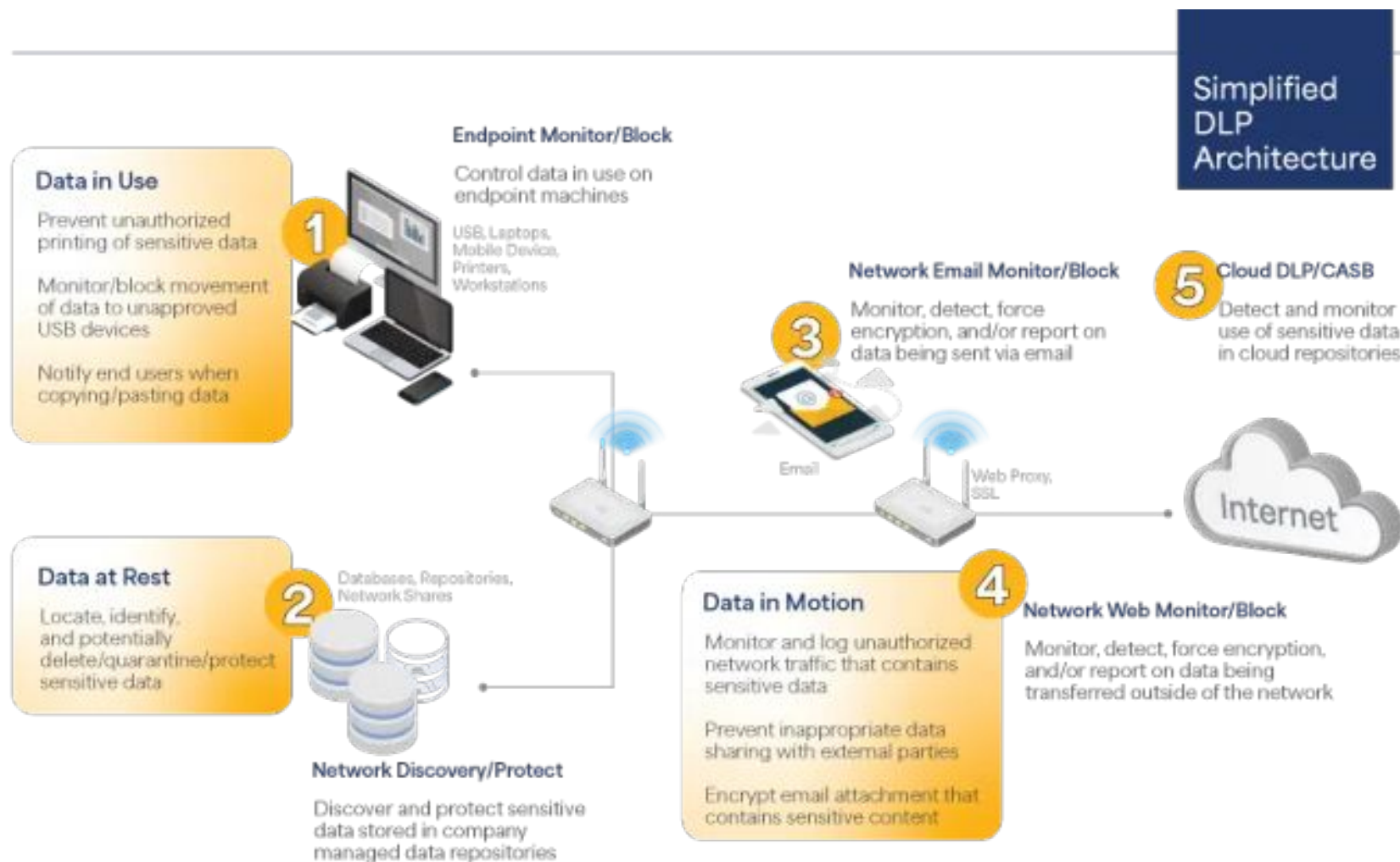


Data Loss Prevention (DLP)

Data State	Description	Example Threat
Data at rest	Stored data in databases, drives	Unencrypted files on shared folders
Data in motion	Data moving across networks	Email with confidential attachment
Data in use	Data actively being accessed	Copy-pasting sensitive content



DLP Architecture



Document Management Policies and Compliance

- **Retention & Disposal Policies**

- Automated archival, secure deletion (e.g., DoD 5220.22-M standard)

- **Legal and Regulatory Standards**

- GDPR – consent, right to erasure, data minimization
- HIPAA – health information protection
- ISO/IEC 27001 – control A.8.3 for document protection

- **Organizational Policies**

- Document classification schemes (confidential, public, internal)
- Employee training & awareness

Discussion

